

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01 Total Marks:100

Annexure A VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

S.No .	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding (20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities (20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	

		user awareness.				
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Q1. TJX Companies Wireless Network Breach, 2005–2007

1. Incident Background and Technical Understanding

1.1.Overview

Between July 2005 and January 2007, TJX Companies Inc. (parent company of retail chains including T.J. Maxx and Marshalls) suffered one of the largest payment-card data breaches disclosed at the time. Attackers gained unauthorized access to the company's internal network through a poorly secured wireless connection at a retail store and used that foothold to reach central transaction processing systems, eventually exfiltrating tens of millions of customer payment-card records over an extended, largely undetected period.

1.2 Timeline of the Incident

Period	Event
Mid-2005	Initial unauthorized wireless access believed to have begun, exploiting the weak WEP encryption still in use at store locations.
2005–2006	Attackers moved laterally from store-level wireless networks into TJX's central databases and payment-processing systems, remaining undetected for an extended period.
December 2006	TJX identified suspicious activity on its computer systems and began an internal investigation.
January 2007	TJX publicly disclosed the breach, revealing exposure of an estimated 45+ million payment-card records (later estimates rose higher).
2007–2009	Regulatory investigations, class-action litigation, and a settlement with the FTC followed, along with a \$9.75 million multistate settlement.

1.3 Affected Organization

TJX Companies Inc., a large multinational off-price retailer operating chains such as T.J. Maxx, Marshalls, and HomeGoods across the United States, Canada, and parts of Europe. The breach affected both retail store infrastructure and centralized corporate systems that processed customer transactions across the retail chain.

1.4 Threat Actor

The intrusion was attributed to an organized cybercriminal group with the technical capability to conduct wireless eavesdropping ("wardriving"), exploit weak encryption, and perform sustained lateral movement within corporate networks. Individuals later linked to the case were also connected to other major payment-card breaches, indicating a financially motivated group specializing in large-scale card-data theft.

1.5 Wireless Technology and Attack Context

Figure 1: TJX Wireless Breach - Attack Chain



At the time of the breach, TJX stores used 802.11b/g wireless local area networks to connect point-of-sale (POS) terminals, price-checking devices, and inventory equipment to store servers. The wireless networks were still using Wired Equivalent Privacy (WEP) encryption while a transition to the stronger Wi-Fi Protected Access (WPA) standard was in progress but incomplete across all locations. WEP was already publicly known to be cryptographically weak and crackable within minutes using freely available tools. Attackers are believed to have used a directional antenna from outside a Marshalls store parking lot to intercept and decrypt

wireless traffic, then used the recovered credentials and network access to pivot into TJX's broader corporate network, where they installed sniffing tools to capture card data in transit and at rest.

2. Identification of Wireless Vulnerabilities

The technical investigation and subsequent regulatory findings identified multiple interrelated weaknesses spanning wireless standards, encryption, authentication, access-point configuration, and overall network architecture.

- **Obsolete Encryption Standard (WEP):** Store wireless networks relied on WEP, which uses a static, easily recoverable RC4 key stream. Publicly available tools of the era could recover a WEP key from captured traffic within minutes, giving attackers effectively unauthenticated access to the wireless segment.
- **Incomplete WPA Migration:** TJX had begun migrating to WPA but had not completed the rollout across all store locations, leaving a mixed environment where the weakest-configured access point determined the real security posture of the wireless estate.
- **Weak or Absent Wireless Authentication:** Wireless access relied on shared, pre-configured keys rather than per-user or per-device enterprise authentication (e.g., 802.1X/EAP with RADIUS), meaning a single compromised key exposed every device on the network.
- **Lack of Network Segmentation:** Store wireless networks were not adequately isolated from the systems that handled payment transactions and from the central corporate network. Once inside the wireless segment, attackers were able to reach systems well beyond the intended scope of in-store wireless connectivity.
- **Inadequate Wireless Access-Point Configuration:** Access points appear to have been deployed with default or minimally hardened settings, without controls such as MAC filtering, rogue-AP detection, or restricted broadcast range, making unauthorized reception of the signal from outside store premises possible.
- **Insufficient Monitoring and Intrusion Detection:** The intrusion persisted undetected

for an extended period (accounts vary, but well over a year), indicating an absence of effective wireless intrusion detection, log correlation, and anomaly monitoring capable of flagging unusual data flows or unauthorized devices.

- **Insecure Transmission and Storage of Payment Data:** Once inside, attackers were able to capture card-transaction data that was insufficiently protected in transit and, in some cases, retained longer than necessary, which amplified the volume and sensitivity of data exposed.

3. Risk, Impact, and Root-Cause Analysis

3.1 Attack Vector Summary

The confirmed attack path proceeded from (1) passive wireless eavesdropping outside a retail store, to (2) cryptographic recovery of the WEP key, to (3) authenticated access to the in-store wireless LAN, to (4) lateral movement into central systems due to inadequate segmentation, to (5) installation of data-capture tools, and finally (6) sustained, undetected exfiltration of payment-card data over an extended period.

3.2 Root-Cause Analysis

The root cause was not a single failure but a chain of compounding weaknesses: an outdated encryption protocol was retained past its useful security life; the transition to a stronger protocol was not completed uniformly; network architecture did not enforce the principle of least privilege between wireless access and sensitive back-end systems; and monitoring controls were not sufficient to detect anomalous behavior once the perimeter was breached. Each individual weakness might have been survivable in isolation, but together they allowed a relatively low-cost, non-invasive attack (wireless eavesdropping) to escalate into a nationwide-scale data breach.

3.3 Affected Assets

- In-store wireless access points and associated network infrastructure
- Point-of-sale (POS) terminals and transaction-processing systems
- Central databases storing historical and current payment-card transaction data
- Customer personally identifiable information (PII) linked to card transactions
- Corporate reputation and brand trust across affected retail chains

3.4 Likelihood and Impact Assessment

Figure 2: Risk Rating Summary - TJX Wireless Vulnerabilities

Vulnerability	Likelihood	Impact	Overall Risk
WEP encryption in use	High	Critical	Critical
Incomplete WPA migration	High	High	High
Weak wireless authentication	High	High	High
Lack of network segmentation	Medium	Critical	Critical
Poor AP configuration/hardening	Medium	Medium	Medium
Insufficient monitoring/IDS	Medium	High	High
Insecure handling of card data	Medium	Critical	Critical

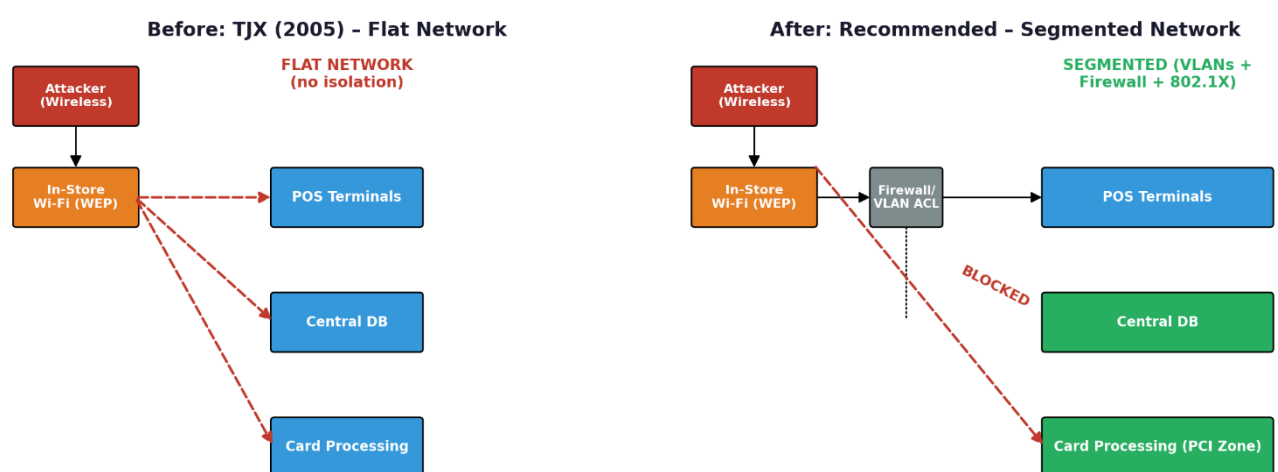
3.5 Operational, Financial, Privacy, Legal, and Reputational Impact

- **Operational Impact:** Store and corporate systems required extensive remediation, forensic investigation, and re-architecture of wireless and network segmentation controls, disrupting normal IT operations for an extended period.

- **Financial Impact:** TJX disclosed costs exceeding \$250 million related to the breach, covering forensic investigation, legal settlements, card-reissuance costs to banks, regulatory fines, and security remediation, including a \$9.75 million multistate settlement and separate FTC settlement.
- **Privacy Impact:** Tens of millions of customers had payment-card data and, in some cases, associated personal information exposed, creating downstream risk of fraud and identity theft for affected individuals.
- **Legal and Regulatory Impact:** The breach triggered investigations by the Federal Trade Commission, multiple state attorneys general, and payment-card industry bodies, resulting in consent orders requiring implementation of a comprehensive information-security program subject to independent audits for 20 years.
- **Reputational Impact:** The breach was, at the time, one of the largest publicly disclosed retail data breaches, generating sustained negative media coverage and eroding customer trust in the affected retail brands.

4. Security Recommendations and Mitigation Measures

Figure 3: Network Architecture Before vs. After Remediation



- **Migrate Fully to WPA2/WPA3-Enterprise:** Replace WEP entirely with WPA2-Enterprise, or preferably WPA3-Enterprise where hardware supports it, across every store location without exception. A phased or partial rollout should never be allowed

to persist in production; legacy WEP access points should be disabled until upgraded.

- **Enforce Enterprise (802.1X/EAP) Authentication:** Replace shared pre-shared keys with per-device or per-user authentication via 802.1X and a RADIUS server, so that a single compromised credential does not grant blanket network access and compromised devices can be individually revoked.
- **Implement Strict Network Segmentation:** Isolate in-store wireless networks from point-of-sale systems and the central corporate network using VLANs and firewalled zones, following least-privilege principles so wireless clients cannot reach payment-processing systems directly.
- **Deploy Rogue Access Point and Wireless Intrusion Detection:** Implement wireless intrusion detection/prevention systems (WIDS/WIPS) to detect rogue access points, unusual signal sources, and anomalous wireless traffic patterns in real time.
- **Harden Access Point Configuration:** Apply MAC filtering, disable unnecessary management interfaces, change default credentials, restrict transmit power to limit signal leakage beyond store premises, and keep firmware patched.
- **Strengthen Payment Data Protection (PCI DSS Alignment):** Encrypt cardholder data in transit and at rest, minimize retention of sensitive authentication data, and align controls with PCI DSS requirements for network segmentation, encryption, and access control specific to cardholder data environments.
- **Improve Monitoring, Logging, and Incident Response:** Implement centralized log collection and correlation (SIEM), continuous monitoring for anomalous data flows, and a tested incident-response plan capable of detecting and containing intrusions within hours rather than months.
- **Conduct Regular Wireless Security Audits:** Perform periodic penetration testing and wireless site surveys to identify unauthorized devices, signal leakage, and configuration drift across all store locations.
- **Establish Security Policy and Staff Awareness:** Formalize wireless security policy covering configuration standards, key-rotation schedules, and vendor/third-party access, supported by regular staff training on recognizing and reporting suspicious network activity.

5. Overall Risk-Rating Summary and Conclusion

5.1 Consolidated Risk-Rating Summary

Finding	Risk Rating	Recommended Control
Use of WEP encryption	Critical	Migrate to WPA2/WPA3-Enterprise
Incomplete encryption migration	High	Enforce uniform rollout policy
Weak/shared-key authentication	High	802.1X/EAP with RADIUS
Flat network architecture	Critical	VLAN segmentation, firewalling
Weak AP hardening	Medium	MAC filtering, firmware patching
Absent wireless monitoring	High	WIDS/WIPS, SIEM logging
Weak protection of card data	Critical	PCI DSS-aligned encryption & retention

5.2 Conclusion

The TJX wireless breach illustrates how a single overlooked legacy control — continued use of WEP during an incomplete migration to WPA — combined with flat network architecture and weak monitoring, allowed a low-sophistication wireless attack to escalate into one of the largest payment card breaches of its era. The incident underscores that wireless security cannot be treated in isolation: encryption strength, authentication design, network

segmentation, and monitoring must be implemented together and consistently across every location, since attackers will target the weakest configured entry point in the estate. Full adoption of WPA2/WPA3-Enterprise authentication, strict segmentation between wireless and payment systems, continuous wireless intrusion monitoring, and alignment with PCI DSS requirements would have substantially reduced both the likelihood and impact of this breach.

5.3 References

- Federal Trade Commission, "TJX Companies, Inc. In the Matter of," FTC File No. 072 3055, 2008.
- Privacy Rights Clearinghouse, Chronology of Data Breaches – TJX Companies entry.
- Multistate settlement agreement documents between TJX Companies Inc. and U.S. state attorneys general, 2009.
- IEEE 802.11 standard documentation on WEP and WPA/WPA2 security mechanisms.
- PCI Security Standards Council, Payment Card Industry Data Security Standard (PCI DSS), relevant version.